Données à caractère personnel & RGPD

BTS SIO 1ère année

Reconnaître une donnée personnelle, appliquer le RGPD, sensibiliser

Données personnelles & RGPD

Objectifs

- Définir une donnée à caractère personnel et une donnée sensible.
- Rappeler les grandes obligations du RGPD et le rôle de la CNIL.
- Identifier les données personnelles traitées dans une situation professionnelle donnée.
- Produire un support de sensibilisation simple destiné à des utilisateurs.

Prérequis

- DICP (disponibilité, intégrité, confidentialité, preuve) — SQ01.
- Notion de base de données et de stockage de l'information — Bloc 1.

Sommaire

Partie	Contenu
Partie 1	Une donnée qui engage
Partie 2	Repérer et sensibiliser — Auto-école Permis+

Partie 1 — Une donnée qui engage

Le cas du jour

Une association sportive gère un fichier d'adhérents : nom, email, date de naissance, certificat médical. Un bénévole propose de le partager par mail à toute l'équipe « pour gagner du temps ». Qu'est-ce qui pose problème ici — et est-ce seulement une question de sécurité informatique ?

Une donnée à caractère personnel

Une **donnée à caractère personnel** est toute information se rapportant à une personne physique identifiée ou identifiable, directement ou indirectement : nom, adresse, date de naissance, numéro de téléphone, email, identifiant en ligne (adresse IP, cookie), photo, voix, numéro de sécurité sociale, plaque d'immatriculation.

Une donnée réellement **anonymisée** (impossible à ré-identifier) échappe à cette définition. Une donnée seulement **pseudonymisée** (un identifiant à la place d'un nom, mais reliable à la personne par ailleurs) y reste soumise.

Des données sensibles, un régime renforcé

Certaines catégories de données personnelles sont protégées plus strictement : origine raciale ou ethnique, opinions politiques ou religieuses, appartenance syndicale, **données de santé**, données biométriques ou génétiques, vie ou orientation sexuelle. Leur traitement est interdit par défaut, sauf exception prévue par la loi.

> **Dans le cas du jour.** Le certificat médical est une donnée de santé — une donnée sensible, pas une donnée personnelle ordinaire.

Pourquoi ce n'est pas qu'une question DICP

Le DICP (disponibilité, intégrité, confidentialité, preuve, déjà vu en SQ01) dit **ce qui est menacé** : ici, la confidentialité, si le fichier partagé par mail tombe entre de mauvaises mains.

Le RGPD ajoute un **cadre légal** que la sécurité seule ne couvre pas : même un fichier parfaitement sécurisé doit respecter des règles sur *pourquoi* on collecte ces données, *combien de temps* on les garde, et *quels droits* ont les personnes concernées.

> **À retenir**
>
> Le DICP protège contre une attaque ; le RGPD encadre un usage, même sans attaque.

Les grands principes du RGPD

Principe	Ce qu'il impose
Finalité déterminée	Un objectif précis annoncé à l'avance, pas un usage détourné ensuite
Base légale	Une raison qui autorise le traitement (contrat, obligation légale, consentement, intérêt légitime)
Minimisation	Ne collecter que ce qui est nécessaire à cette finalité
Limitation de conservation	Une durée définie, pas indéfinie
Droits des personnes	Accès, rectification, effacement, opposition à leurs propres données

Dans le cas du jour. Partager le fichier « pour gagner du temps » n'a pas de finalité précise — ce motif ne suffit pas à justifier l'envoi.

Le rôle de la CNIL

La **Commission Nationale de l'Informatique et des Libertés** est l'autorité française chargée de veiller au respect du RGPD : elle informe et conseille, contrôle la conformité (et peut sanctionner), reçoit les plaintes des personnes concernées, et publie des guides pratiques accessibles à tous.

Exercice — Vérification individuelle

5 minutes · seul. Pour chaque élément, indiquer s'il s'agit d'une donnée personnelle « ordinaire », d'une donnée sensible, ou d'une donnée non personnelle :

1. Le nom d'un adhérent
2. Le certificat médical d'un adhérent
3. Le nombre total d'adhérents de l'association
4. L'adresse email d'un adhérent
5. Le logo de l'association

Partie 2 — Repérer et sensibiliser : Auto-école Permis+

Permis+ est une petite auto-école (3 salariés) qui inscrit ses élèves via une fiche papier, avant de saisir les informations dans un logiciel de gestion. La fiche d'inscription actuelle demande :

- Nom, prénom, date de naissance, photo d'identité
- Adresse postale, numéro de téléphone, email
- Photocopie de la pièce d'identité et numéro de sécurité sociale (financement CPF)
- Coordonnées bancaires (prélèvement des mensualités)
- Pour le permis moto ou poids lourd : une attestation d'aptitude médicale

Exercice 1 — Repérer les données

15 minutes · en binôme, sur ordinateur ou sur papier.

Construire un tableau à trois colonnes — *donnée*, *personnelle ordinaire ou sensible ?*, *nécessaire ou excessive par rapport à l'inscription ?* — et le compléter pour chacune des données listées ci-dessus.

Construire un support de sensibilisation

Un bon support de sensibilisation, pour des utilisateurs non spécialistes :

- s'adresse à un **destinataire précis** (ici : les 3 salariés de Permis+) ;
- porte **2 à 3 messages clés**, pas un cours complet ;
- donne au moins **un exemple concret à éviter**, pas seulement une règle abstraite ;

- tient sur **une seule page ou un seul écran**.

Exercice 2 — Produire le support

30 minutes · en binôme, sur ordinateur (traitement de texte, présentation) ou sur papier/carton.

Produire une fiche ou affiche de sensibilisation destinée aux salariés de Permis+, sur la protection des données des élèves :

1. Choisir 2 ou 3 messages clés, à partir de ce que le tableau de l'exercice 1 a révélé.
2. Formuler chaque message simplement, sans jargon RGPD non expliqué.
3. Ajouter au moins un exemple concret à éviter.
4. Mettre en forme sur une page ou une affiche.

Critère de réussite : un salarié de Permis+ sans formation informatique doit comprendre le support en moins d'une minute de lecture.

Corrigés

BTS SIO 1ère année

Reconnaître une donnée personnelle, appliquer le RGPD, sensibiliser

Données personnelles & RGPD

Partie 1 — Vérification individuelle

1. Le nom d'un adhérent — donnée personnelle ordinaire.
2. Le certificat médical d'un adhérent — donnée sensible (donnée de santé).
3. Le nombre total d'adhérents — donnée non personnelle (statistique agrégée, ne désigne personne en particulier).
4. L'adresse email d'un adhérent — donnée personnelle ordinaire.
5. Le logo de l'association — donnée non personnelle.

Partie 2 — Exercice 1 (repérage)

Donnée	Type	Nécessaire ou excessive
Nom, prénom, date de naissance	Personnelle ordinaire	Nécessaire : identifier l'élève, vérifier l'âge minimum légal
Adresse postale, téléphone, email	Personnelle ordinaire	Nécessaire : contact et suivi administratif
Photo d'identité	Personnelle ordinaire	Nécessaire : dossier d'examen du permis
Photocopie de la pièce d'identité	Personnelle ordinaire	Nécessaire : vérification d'identité réglementaire
Numéro de sécurité sociale	Personnelle ordinaire, à traiter avec précaution	Nécessaire uniquement si financement CPF demandé — excessif sinon
Coordonnées bancaires	Personnelle ordinaire, sensible en pratique (fraude)	Nécessaire pour le prélèvement des mensualités
Attestation d'aptitude médicale	**Sensible** (donnée de santé)	Nécessaire uniquement pour les permis concernés (moto, poids lourd) — excessif pour un permis B classique

Le point à faire ressortir en restitution : le numéro de sécurité sociale et l'attestation médicale ne sont légitimes que pour une partie des élèves — les collecter systématiquement, pour tout le monde, viole le principe de minimisation.

Partie 2 — Exercice 2 (exemple de support)

Un exemple recevable, à titre d'illustration (la production attendue peut différer dans la forme, pas dans l'esprit) :

Protéger les données de nos élèves — 3 réflexes

1. Je ne demande le numéro de sécurité sociale et l'attestation médicale que si l'élève en a réellement besoin (CPF, permis moto/poids lourd) — pas par défaut.
2. Je ne transfère jamais une fiche d'élève complète par mail personnel ou messagerie non professionnelle.
3. Je range les fiches papier hors de vue du public, et je supprime les fichiers numériques des élèves qui ont arrêté leur formation depuis plus d'un an.

Un support qui reformule ces idées avec d'autres mots, dans un ordre différent, ou avec un exemple différent mais tout aussi concret, doit être valorisé de la même façon.